PHISHING DETECTION & AWARENESS REPORT

Phishing

Email Analysis & Awareness

PREPARED BY	Shawn Ryan
DATE	March 23, 2026
TYPE	Security Awareness Report
AUDIENCE	Employees & Management
METHODOLOGY	Manual Email Analysis + OSINT

3

Phishing Emails Analyzed

Real-world samples examined in detail

10+

Indicators Identified

Tactics, techniques & red flags logged

100%

Passive — No Exploitation

Read-only analysis, zero harmful actions

Educational report — all email samples are publicly available phishing examples. No exploitation or illegal activity performed.

What Is Phishing?

Phishing is a cyber attack where criminals disguise themselves as trusted entities — banks, employers, or service providers — to trick users into revealing passwords, financial data, or personal information. It is the #1 cause of data breaches worldwide.

Email Phishing

Mass-sent fake emails impersonating well-known brands. Targets thousands at once with identical bait.

Spear Phishing

Highly targeted attack using personal details about the victim. Far more convincing than bulk phishing.

Smishing / Vishing

Phishing delivered via SMS text messages (smishing) or phone calls (vishing) instead of email.

Whaling

Spear phishing targeting C-suite executives. Attackers impersonate legal, financial, or board contacts.

91% of cyberattacks start with a phishing email

$4.9M average cost of a phishing-related breach (IBM 2023)

3.4B phishing emails sent every single day worldwide

How a Phishing Attack Works

01

🎯 Reconnaissance

Attacker researches the target — name, employer, email format, contacts — via LinkedIn, social media, or data leaks.

02

✍️ Crafting the Lure

A convincing fake email is created, mimicking a known brand. Logos, signatures, and domain names are spoofed.

03

📤 Delivery

Email is sent to the target. May include a malicious link, fake login page, or infected attachment.

04

🖱️ User Interaction

Victim clicks the link or downloads the file. A fake website captures credentials or malware is installed silently.

05

💀 Exploitation

Attacker gains access using stolen credentials — bank accounts, email, corporate systems. Damage begins.

06

🚨 Impact

Data theft, financial fraud, ransomware deployment, or account takeover. Cleanup costs average $4.9M.

Section 1: Phishing Email Analysis

Three real-world phishing email samples examined in detail

SAMPLE 1 OF 3

Account Suspension Threat (Bank Impersonation)

✉ Simulated Email Preview

From: security@secure-bankverify.net

To: user@company.com

Subject: ⚠️ Urgent: Your Account Will Be Suspended

Date: March 19, 2026 9:14 AM

Dear Valued Customer,

We have detected unusual activity on your account. To prevent suspension, you must verify your identity immediately.

👉 Click here to verify: http://secure-bankverify[.]net/login

Failure to verify within 24 hours will result in permanent account closure.

— Security Department
National Trust Bank

🔍 PHISHING INDICATORS IDENTIFIED

Spoofed Domain
'secure-bankverify.net' — not a real bank domain. Legitimate banks use their official domain only.

Fear & Urgency Tactics
"Suspend" and "24 hours" pressure the user to act without thinking — classic social engineering.

Generic Greeting
"Dear Valued Customer" — real banks address you by name. No name = bulk phishing.

Suspicious URL
Link goes to 'secure-bankverify[.]net' not the real bank. Domain registered 3 days before send date.

Sender Mismatch
Display name says 'National Trust Bank' but actual email domain is unrelated third-party.

No Official Contact Info

🔴 **RISK CLASSIFICATION: PHISHING — HIGH CONFIDENCE**

SAMPLE 2 OF 3

IT Helpdesk Password Reset (Corporate Impersonation)

✉ Simulated Email Preview

From: it-support@company-helpdesk.xyz

To: shawn.ryan@company.com

Subject: ACTION REQUIRED: Reset Your Password Now

Date: March 20, 2026 11:52 AM

Hi Shawn,

Our system detected that your account password expires TODAY. You must reset it immediately to maintain access to company resources.

🔑 Reset Password: http://company-helpdesk[.]xyz/reset?id=SR2891

If you do not reset within 2 hours, your account will be disabled and IT will need to manually re-enable it.

— IT Helpdesk Team

🔍 PHISHING INDICATORS IDENTIFIED

External Domain Impersonating IT
Real IT helpdesks use your company's own domain (e.g., @company.com), not an external xyz domain.

Uses Real Name (Spear Phishing)
Attacker researched victim's name from LinkedIn. Personalization increases click rates by 3x.

Extreme Urgency — 2-Hour Deadline
Artificial time pressure forces rash action. Real IT systems give advance notice of expiry.

Malicious Reset Link
URL contains tracking ID. Clicking sends credentials to attacker-controlled server.

No Official IT Ticket Number
Real helpdesk emails always include a ticket/case number for tracking. This has none.

🟠 **RISK CLASSIFICATION: PHISHING — SPEAR PHISHING VARIANT**

SAMPLE 3 OF 3

Prize / Package Delivery Scam (Curiosity Lure)

✉ Simulated Email Preview

From: noreply@fedex-delivery-notify.com

To: user@gmail.com

Subject: 🎁 Your Package Is On Hold — Action Required

Date: March 21, 2026 3:22 PM

Dear Customer,

A package addressed to you could not be delivered due to an incomplete address. To schedule redelivery, you must pay a small holding fee of $2.99.

📦 Update Delivery Address: http://fedex-delivery-notify[.]com/track?pkg=38812

Your package will be returned to sender in 48 hours if no action is taken.

— FedEx Customer Service

🔍 PHISHING INDICATORS IDENTIFIED

Fake Carrier Domain
Real FedEx uses fedex.com only. 'fedex-delivery-notify.com' is a copycat domain registered to harvest payment data.

Payment Harvesting Lure
The $2.99 'fee' is designed to collect your full credit card details — not to charge $2.99.

Tracking Link with ID
URL contains a unique ID to track who clicked. Leads to a fake FedEx login/payment page.

48-Hour Pressure
Fake urgency forces action before the victim thinks to verify through the real FedEx website.

No Tracking Number Shown
Legitimate delivery notices always include the actual package tracking number in the email body.

🟡 **RISK CLASSIFICATION: PHISHING — PAYMENT HARVESTING SCAM**

How to Analyze an Email Header

Email headers contain invisible metadata that reveals where an email actually came from — even if the visible sender looks legitimate.

1 Open the Raw Header

In Gmail: ⋮ menu → 'Show original'. In Outlook: File → Properties. Copy the full header block.

2 Paste into Analyzer Tool

Use Google Admin Toolbox (toolbox.googleapps.com) or MXToolbox (mxtoolbox.com/EmailHeaders.aspx).

3 Check 'Received From'

Trace the chain of servers the email passed through. The originating IP should match the claimed sender's domain.

4 Check SPF / DKIM / DMARC

These are authentication records. FAIL on any of these = the sender domain is likely spoofed.

5 Check Reply-To vs From

If Reply-To differs from From address, replies go to the attacker. Major red flag in phishing emails.

6 Lookup Originating IP

Paste the sending IP into AbuseIPDB.com or VirusTotal. Known phishing servers appear in threat databases.

🔧 Tools: toolbox.googleapps.com/apps/messageheader | mxtoolbox.com/EmailHeaders.aspx | abuseipdb.com | virustotal.com

Section 2: Awareness & Prevention

Practical guidance every employee needs to know

RED FLAGS

10 Universal Phishing Red Flags

01 Suspicious sender domain

Sender uses a lookalike domain (amazon-support.net vs amazon.com) or unrelated third party.

02 Urgency and fear language

"Act now", "24 hours", "suspended", "verify immediately" — designed to disable critical thinking.

03 Generic greeting

"Dear Customer" or "Dear User" instead of your actual name. Real companies know who you are.

04 Unexpected attachment

Unsolicited .zip, .exe, .docm, or .pdf files. Even Office files can contain macros that run malware.

05 Mismatched or suspicious URL

Hover over any link — if the destination URL doesn't match the expected domain, do not click.

06 Poor grammar or spelling

Not always present in modern AI-generated phishing, but still common in lower-effort campaigns.

07 Requests for credentials/OTP

No legitimate company will ask for your password or OTP via email — ever, for any reason.

08 Unusual sender for the context

Your 'CEO' emailing from Gmail, or IT support emailing from Yahoo — immediate red flag.

09 Too-good-to-be-true offers

Prize winnings, inheritance claims, or refund notifications you didn't initiate are almost always scams.

10 Missing official contact info

Legitimate emails include phone numbers, official addresses, and proper corporate signatures.

CLASSIFICATION

Email Risk Classification Framework

🟢 **SAFE**

Legitimate Email

INDICATORS:

- Sender domain matches official company domain
- SPF / DKIM / DMARC all PASS
- No urgency, fear, or pressure tactics
- Links go to expected, verified domains
- Addressed to you by name with proper signature

RECOMMENDED ACTION:

No action required. Safe to interact with normally.

🟡 **SUSPICIOUS**

Potentially Unwanted / Uncertain

INDICATORS:

- Sender domain is slightly unfamiliar
- Generic greeting used
- One or two minor red flags present
- Link destination is unclear or uses URL shortener
- Unexpected but not obviously malicious content

RECOMMENDED ACTION:

Do NOT click links or open attachments. Forward to IT/security team for review.

🔴 **PHISHING**

Confirmed Phishing Attempt

INDICATORS:

- Multiple red flags present simultaneously
- Domain clearly spoofed or mismatched
- Requests credentials, payment, or OTP
- SPF / DKIM / DMARC FAIL
- Link leads to fake login or payment page

RECOMMENDED ACTION:

Do NOT click anything. Do NOT reply. Report to IT security immediately. Delete the email.

Employee Do's & Don'ts

✅ DO — Best Practices

- Verify the sender's full email address — not just the display name
- Hover over all links before clicking to preview the destination URL
- Contact the sender through a separate, known channel to verify suspicious requests
- Report suspicious emails to your IT/security team immediately
- Use multi-factor authentication (MFA) on all accounts
- Keep software and antivirus updated to catch known malware
- Attend phishing awareness training when offered by your employer
- When in doubt, delete the email and verify through official channels

🚫 DON'T — Dangerous Behaviors

- Don't click links in unexpected emails — go directly to the official website
- Don't open attachments from unknown or unexpected senders
- Don't enter passwords or OTPs on pages you reached via an email link
- Don't trust emails just because they look official or use company logos
- Don't act on 'urgent' requests without verifying through a separate channel
- Don't forward suspicious emails to colleagues — report to IT only
- Don't assume your spam filter catches everything — it doesn't
- Don't ignore security awareness training or phishing simulation emails

PREVENTION

Organizational Prevention Guidelines

🛡️ Technical Controls

- Enable SPF, DKIM, and DMARC on all email domains
- Deploy email security gateway (Proofpoint, Mimecast, or MS Defender)
- Enable MFA across all corporate accounts and systems
- Use URL rewriting / link scanning in email clients
- Block macro execution in Office documents by default

👥 Employee Training

- Run phishing simulation campaigns quarterly (e.g., GoPhish, KnowBe4)
- Provide mandatory security awareness training annually
- Create a clear, simple process for reporting suspicious emails
- Reward employees who correctly identify and report phishing attempts
- Brief new hires on phishing threats during onboarding

📋 Policy & Governance

- Document an incident response plan for phishing attacks
- Define clear escalation paths: employee → IT → security team
- Establish a 'verify before you click' culture at all levels
- Log all reported phishing attempts and track trends over time
- Include phishing risk in the annual security risk assessment

🔍 Monitoring & Response

- Monitor email logs for signs of credential harvesting
- Set up alerts for logins from unexpected geographic locations
- Conduct post-incident reviews after every successful phishing attack
- Subscribe to threat intelligence feeds for new phishing campaigns
- Run tabletop exercises simulating a phishing breach scenario

Key Takeaways

01 Phishing is the #1 entry point for cyberattacks. Human awareness is the most effective defense.

02 Always verify the sender's domain, inspect links before clicking, and trust your instincts.

03 Urgency and fear are psychological weapons. Slow down — legitimate organizations do not threaten immediate account closure.

04 No company will ever ask for your password or OTP via email. Period.

05 When in doubt, report it. Reporting a false positive is always better than ignoring a real attack.